# Inledning

Den här rapporten analyserar sex säkerhetsincidenter som är relaterade till Identity and Access Management (IAM) hos AcmeDataCorp, ett medelstort företag inom finansindustrin. Syftet med rapporten är att identifiera svagheter inom IAM miljön, genomföra en omfattande riskbedömning och ge motiverade rekommendationer. Rapporten omfattar innehåll från riktlinjer och principer i ett flertal standarder såsom NIST SP 800-53 (Access Control), ISO 27001 (Information Security Management) och CIS Controls, samt efterlevnadskraven i GDPR när det gäller hantering av personuppgifter. Rapporten syftar till att visa djupgående kunskap om IAM koncepten, bland annat genom att lyfta fram problem med hur RBAC är designat, hur användarkonton hanteras och hur rättigheter tilldelas som delar av en strategi för att följa de krav som ställs för att minska risken för informationsläckage, insiderhot och överträdelser av regler och lagstiftning.

Rapporten är uppbyggd i fyra avsnitt: miljö, incidentanalys, riskbedömning och rekommendationer.

# Del 1 – Miljöbeskrivning

AcmeDataCorps IAM miljö är utformad för att skydda känsliga kunduppgifter, interna ekonomiska rapporter och kritiska IT resurser i en finansiell miljö, där efterlevnad med GDPR och ISO 27001 är centralt. Miljön bygger på en kombination av roller, åtkomstkontroller och autentiseringsmekanismer, men visar tecken på implementationbrister som utsätter organisationen för hot.

## Roller och Ansvar

Organisationen har en tydlig rollfördelning som klargör ansvar:

- **Finance**: Hanterar ekonomiska data och rapporter; ansvarar för daglig hantering av finansiella resurser.
- **HR**: Ansvarar för personaldata, rekrytering och offboarding; hanterar känsliga personuppgifter.
- **IT Admins**: Administrerar IT system, inklusive IAM konfigurationer; har höga privilegier för underhåll.
- **Managers**: Övervakar team och har översiktlig åtkomst till data för beslutsfattande.
- **Interns**: Tillfälliga roller för lärlingar; ska ha begränsad åtkomst för att minimera risker.

Dessa roller tilldelas via grupper i Active Directory (AD), i linje med RBAC principer (NIST AC-6), där roller ska spegla affärsbehov och Least Privilege.

## Skyddsvärda Resurser

Nyckelresurser inkluderar:

- **Finance Docs**: Innehåller känsliga ekonomiska filer; skyddas mot obehörig modifiering för att upprätthålla dataintegritet.
- **Archive**: Historiska data tillgängliga för alla med läs rättigheter; IT Admins har full kontroll för arkivering.
- **TopSecret IT**: Kritiska IT konfigurationer; begränsad till IT Admins för att förhindra systemstörningar.
- **Common**: Delad mapp för allmänna filer; alla har Modify rättigheter, vilket ökar risken för dataläckage.

Dessa resurser klassificeras enligt NISTs dataklassificering (FIPS 199), där Finance Docs och kunddata betraktas som högkänsliga.

## Hur Åtkomstmodellen Fungerar

AcmeDataCorp använder RBAC som grund, där roller tilldelar rättigheter via grupper. Åtkomst styrs med:

- **DACL (Discretionary Access Control Lists)**: Definierar specifika rättigheter (Read, Write, Modify, Delete) per resurs, ägd av resursägare.
- **SACL (System Access Control Lists)**: Loggar åtkomstförsök och förändringar för audit spårbarhet (ISO 27001 A.12.4).
- Principen om Least Privilege (NIST AC-6) ska gälla, men implementationen är inkonsekvent, vilket leder till överprivilegiering.

Modellen kombinerar RBAC med DAC för flexibilitet, men saknar strikt Separation of Duties (SoD) för att förhindra konflikter.

## Autentiseringsmetoder

Autentisering baseras på lösenord med minimikrav (längd, komplexitet) enligt företagspolicy. MFA är obligatoriskt för IT Admins men endast rekommenderat för övriga, i strid med NIST SP 800-63B som rekommenderar MFA för alla känsliga roller. Inloggningar loggas med Success/Failure för övervakning.

## Hotbilder Organisationen Är Mest Utsatt För

Som finansföretag är AcmeDataCorp utsatt för:

- **Insider Threats**: Anställda eller ex anställda som utnyttjar kvarvarande åtkomst (CIS Control 16).
- **Dataläckage**: Oavsiktlig eller avsiktlig exponering av kunddata, med GDPR böter som konsekvens.
- **Extern Brute Force**: Angrepp mot svaga autentiseringar, särskilt nattetid.
- **Privilege Escalation**: Felaktig tilldelning som tillåter självhöjande av rättigheter.

- **Supply Chain Risks**: Via interns eller temporära roller.

Dessa hot förstärks av bristande livscykelhantering, som skapar "ghost accounts" (NIST IR 7966).

# Del 2 – Incidentanalys

Här analyseras de sex incidenterna med fokus på mekanismer, brutna principer och IAM implikationer. Analysen knyter till standarder för att visa djup: t.ex. hur RBAC designfel (CIS 4.1) leder till Least Privilege brott.

## Incident 1: Intern Modifierar Finance Reports

**Vad som hände**: En intern ändrade av misstag en ekonomifil i Finance Reports mappen.
**Användare/Roll**: Interns gruppen.
**Access försök**: Modify (Write/Delete).
**Brutna principer**: Least Privilege och Need to Know (NIST AC-6); interns ska inte ha skrivrättigheter till känsliga data.
**Hur det kunde ske**: Felaktig gruppkonfiguration gav Interns Modify rättigheter till Finance Reports, troligen via arv från Common eller manuell fel. RBAC implementationen saknade regelbundna role reviews (ISO 27001 A.9.2).
**Potentiella konsekvenser**: Dataintegritetsbrott, felaktiga rapporter som leder till finansiella beslutsfel, GDPR brott om kunddata påverkas.
**Relevant loggdata**: SACL loggar visar framgångsrik Modify åtgärd från intern konto, ingen alert utlöstes pga avsaknad av anomalidetektion.

**Varför problem ur IAM perspektiv**: Detta avslöjar en brist i RBAC design, där roller inte är tillräckligt detaljerade, vilket ökar insider risker och strider mot CIS Control 14. (Controlled Access Based on Need to Know).

## Incident 2: Ex HR Anställd Loggar In Efter Offboarding

**Vad som hände**: En tidigare HR anställd loggade in två veckor efter sista arbetsdag.
**Användare/Roll**: Tidigare HR.
**Access försök**: Inloggning (Success).
**Brutna principer**: Timely Revocation (NIST AC-2); Separation of Duties i livscykel.
**Hur det kunde ske**: Fördröjd offboarding, kontot avaktiverades inte samma dag, MFA avregistrerades inte, pga manuella processbrister (ISO 27001 A.9.3).
**Potentiella konsekvenser**: Tillgång till persondata, potentiell dataläckage eller sabotage, med GDPR sanktioner upp till 4% av omsättning.
**Relevant loggdata**: Inloggningsloggar visar Success från ex konto, ingen failure alert från offboarding monitorering.

**Varför problem ur IAM perspektiv**: Understryker processbrister i kontohantering, där automatiserad borttagning av åtkomsträttigheter saknas, vilket skapar "zombie accounts" och ökar insiderhot (CIS 5.3).

## Incident 3: 72 Misslyckade Inloggningsförsök från Finance Konto

**Vad som hände**: 72 misslyckade försök på ett Finance konto nattetid (02:00–03:00).
**Användare/Roll**: Finance.
**Access försök**: Inloggning (Failure).
**Brutna principer:** Account Monitoring (NIST AC-7), Least Privilege i autentisering.
**Hur det kunde ske**: Svag lösenordspolicy utan lockout efter failures, ingen MFA krav för Finance, tillåter brute force (CIS 16.7).
**Potentiella konsekvenser**: Potentiell konto övertagande, tillgång till finansdata leder till bedrägeri eller läckage.
**Relevant loggdata**: Inloggnings loggar registrerar 72 failures, ingen realtids alert utlöstes pga bristande SIEM integration.

**Varför problem ur IAM perspektiv**: Avslöjar svagheter i autentiseringslager, där monitorering inte kopplas till incident response, i strid mot ISO 27001 A.16.

## Incident 4: IT Admin Inloggning från Annat Land

**Vad som hände**: IT Admin loggade in från utlandet under semester.
**Användare/Roll**: IT Admins.
**Access försök**: Inloggning (Success).
**Brutna principer**: Geolocation Restrictions (NIST AC-20); Anomaly Detection.
**Hur det kunde ske**: Ingen geo fencing eller contextual MFA; logging fångade aktiviteten men ingen alert (CIS 13.3).
**Potentiella konsekvenser**: Möjlig kontoövertagande, administratörsrättigheter leder till systemkompromiss.
**Relevant loggdata**: Loggar visar Success från ovanlig IP, administratörs aktivitetslogg registrerar åtkomst utanför arbetstid.

**Varför problem ur IAM perspektiv**: Detta pekar på brist i multifaktor kontext, där RBAC inte integreras med riskbaserad autentisering (NIST SP 800-63B).

## Incident 5: Kunddata i Common Mappen

**Vad som hände**: Excel fil med kund personuppgifter placerades i Common mappen.
**Användare/Roll**: Okänd, men tillgänglig för Everyone.
**Access försök**: Modify/Read av alla.
**Brutna principer**: Data Classification och Least Privilege (NIST MP-3).
**Hur det kunde ske**: Felaktig DACL på Common tillåter Modify för alla; ingen DLP (Data Loss Prevention) för att flagga känslig data (ISO 27001 A.8.2).
**Potentiella konsekvenser**: Massdata läckage, GDPR brott med personuppgifts incidentrapportering inom 72 timmar.
**Relevant loggdata**: Åtkomstloggar visar multiple Read/Modify; ingen specifik alert för känslig data.

**Varför problem ur IAM perspektiv**: Avslöjar designfel i resursklassificering, där RBAC inte skiljer på data känslighet, ökar data läckagerisk.

### Incident 6: Manager Lägger Till Sig Själv i Finance Gruppen

**Vad som hände**: En Manager delegerade sig själv till Finance gruppen.
**Användare/Roll**: Managers.
**Accessförsök**: Gruppändring (Modify).
**Brutna Principer**: Separation of Duties och No Self Approval (NIST AC-5).
**Hur det kunde ske**: Felaktig tilldelning i AD, Managers har administrativ behörighet utan approval-workflow (CIS 4.8).
**Potentiella Konsekvenser**: Obehörig åtkomst till finansdata, insider sabotage eller bedrägeri.
**Relevant Loggdata**: Gruppändringsloggar visar att användare själv tilldelat sig gruppbehörighet, ingen SoD alert.

**Varför Problem ur IAM Perspektiv**: Understryker RBAC brister i hantering av privilegier, där PAM (Privileged Access Management) saknas, i strid mot ISO 27001 A.9.4.

## Del 3 – Riskanalys

Incidenterna avslöjar systemiska risker i AcmeDataCorps IAM, som sträcker sig bortom enskilda händelser och visar på processbrister. En heltäckande analys, inspirerad av NIST RMF, identifierar följande områden:

### Bristande Privilegiekontroll

Överprivilegiering (t.ex. Incident 1, 6) bryter mot Least Privilege, vilket ökar insider threats. Utan regelbundna role reviews (CIS 4.1) eskalerar risken för privilege abuse, särskilt i finansbranschen där dataintegritet är kritisk (GDPR Art. 32).

### Felaktig Livscykelhantering

Fördröjda offboardings (Incident 2) skapar kvarvarande åtkomst, en känd attackväg för ex anställdas sabotage (NIST IR 7966). Detta förstärker hotbilder som karriärsabotage, med potentiella efterlevnads brott.

### Svag Autentisering

Otillräcklig universell MFA (Incident 3, 4) exponerar för externa angrepp, som brute force eller phishing. Brister i miljöbaserad säkerhet ökar risken för kontoövertagande, särskilt för privilegierade roller (ISO 27001 A.9.4).

### Avsaknad av Logging/Monitorering

Loggar finns men saknar integration med SIEM för realtidsdetektion (alla incidenter). Detta leder till fördröjd respons, ökande dataläckagerisker (CIS 6.1).

Helhetsbilden visar en splittrad IAM-strategi, där insider hot dominerar på grund av processbrister. Riskerna omfattar finansiella förluster, regulatoriska sanktioner och skadat rykte, som kan förvärras över tid om de inte åtgärdas.

# Del 4 – Förbättringsförslag

Förslagen är motiverade med principer och standarder, fokuserade på avancerade lösningar som PAM och JIT för att bygga en robust IAM strategi.

## IAM Policy

Utveckla en tydlig IAM policy baserad på NIST SP 800-12, inklusive årliga audits. Motivering: Detta åtgärdar brister i RBAC-design (Incident 1, 6) genom att införa detaljerade roller och SoD-kontroller, vilket minskar risken för obehörig åtkomsthöjning.

## Privilegier (PAM/JIT Access/Role Review)

Implementera Privileged Access Management (PAM) med Just In Time (JIT) access för IT Admins och Managers, där rättigheter beviljas temporärt via workflow (CIS 4.3). Motivering: Förhindrar att användare själva tilldelar sig rättigheter (Incident 6) och överprivilegiering (Incident 1), enligt ISO 27001 A.9.2 för regelbundna role reviews, minskade insider risker.

## Livscykelhantering (On/Offboarding)

Automatisera on/offboarding med integration till HR system, inklusive omedelbar indragning av behörigheter och borttagning av MFA registrering (NIST AC-2). Motivering: Löser fördröjningar (Incident 2) genom scriptade processer, säkerställande efterlevnad med GDPR Art. 32 och minimerande "ghost accounts".

## Autentisering (MFA, CA)

Krav på MFA för alla roller med Conditional Access (CA) baserat på plats, tid och risk (NIST SP 800-63B). Motivering: Åtgärda svagheter (Incident 3, 4) genom adaptiv autentisering, integrerat med Azure AD eller liknande, för att blockera avvikelser och uppfylla CIS 16.2.

## Logging & Övervakning

Integrera loggar i ett SIEM system med AI baserad avvikelse detektering för realtids alerts (ISO 27001 A.12.4). Motivering: Förbättrar detektion (alla incidenter) genom samkörning av data, möjliggör snabb respons och Kraven i GDPRs incidentrapportering uppfylls.

Dessa förslag bygger på en integrerad IAM strategi, där tekniska kontroller stöds av processer, för att minska total riskexponering och uppnå högre säkerhetsnivå enligt NIST CSF. Genomförandet bör prioriteras med en testfas för PAM/JIT för att bekräfta resultaten.

# Slutsats

Rapporten understryker behovet av en proaktiv IAM omställning för att skydda AcmeDataCorps tillgångar. Genom att åtgärda identifierade brister kan organisationen minska hotbilder och säkerställa långsiktig efterlevnad. Rekommenderar uppföljningsmöte för implementeringsplan.